Technical Report

Digital Sovereignty and Infrastructure-as-Code Security (L00213621)

In the framework of this assignment, I have developed a Policy-as-Code approach based on Terraform and HashiCorp Sentinel to improve the digital sovereignty and security of the infrastructure of ATUL0012345. It helped me to come up with the rules that would identify and prevent all the deployments of insecure or nonconformable to the requirements infrastructure configurations. In particular, I have focused on the AWS-based infrastructure, geographical limitations, and Terraform supply-chain security.

Implementation and Testing:

The list of the policies implemented includes six policies: approved AWS regions, approved EC2 instance types, EBS encryption, mandatory IMDSv2, restrictions on SSH access and approved Terraform providers. The purpose of each of the mentioned policies is to conduct the audit of the Terraform configuration according to the security requirements of the project.

To test my policies, I have used the Sentinel CLI v0.41.0 together with the mock Terraform data. As a result, the test suite contains 15 test cases (positive and negative). All six policies have successfully passed the tests that means that the rules were properly implemented and able to distinguish complaint and non-complaint cases. Moreover, I have prepared the Terraform execution plan that includes seven resources and saved it as terraform/tfplan.

Limitations and Recommendations:

While limiting infrastructure to approved AWS regions helps achieve digital sovereignty, it does not guarantee that all data will stay inside that jurisdiction. Backup, snapshotting, replicating, and administrative access can all be done from other geographical locations. Hence, it is necessary to implement extra controls to monitor data transfer, storage places, and access permissions. Moreover, one needs to check whether the list of approved regions aligns with the needs of the organization.

Another aspect is supply chain security. Limiting the Terraform providers to an approved source and version constraints help mitigate the problem with the untrusted dependencies. Nevertheless, there is still no way to be sure that a provider does not have vulnerabilities or malicious software inside. Furthermore, the approved provider version constraint i.e 5.0 allows a range of versions rather than an exact version. Although the Terraform lock file records the selected provider version and checksums, further dependency verification is still important.

While Sentinel is helpful in protecting the infrastructure plans before applying them, it is not able to replace continuous monitoring, runtime security, and vulnerability management. The policies were tested locally and were not implemented for HCP Terraform.This assignment provided me with an understanding of how policy as code can help enhance security for infrastructure along with making compliance verifications more consistent. It also made me understand that even with automated policies, complete digital sovereignty, security cannot be achieved.